
AGENTFORGE

RAPPORT DE CERTIFICATION ENTERPRISE

Enterprise Certification Sprint (ECS) -- Rapport Final

Date : 04 Juin 2026

SCORE GLOBAL CERTIFIE

62 / 100

PRE-ENTERPRISE

Classification : PRE-ENTERPRISE (60-69)

Echelle de Classification	
Classe	Plage
Beta	< 50
Production	50-59
Production+	60-69
Pre-Enterprise	70-79
Enterprise	80-89
Enterprise+	90-94
Enterprise Elite	95+

TABLE DES MATIERES

Section 1 -- Architecture Reelle Observee

Section 2 -- Couverture OpenTelemetry

Section 3 -- Resultats TLS

Section 4 -- Resultats PenTest

Section 5 -- Resultats Supply Chain

Section 6 -- Resultats Charge

Section 7 -- Resultats Resilience

Section 8 -- Resultats Multi-Tenant

Section 9 -- Resultats IA

Section 10 -- Vulnerabilites Restantes

Section 11 -- Score Certifie par Domaine

Section 12 -- Score Global Certifie

Ce rapport presente les resultats de l'audit de certification Enterprise du projet AgentForge. Chaque section detaille les observations, les ameliorations apportees et les lacunes restantes.

Section 1 : Architecture Reelle Observee

L'audit a revele une architecture monorepo structuree et moderne, construite autour de l'ecosysteme JavaScript/TypeScript avec une separation claire des responsabilites.

Structure du Monorepo

Le depot utilise Turborepo avec pnpm workspaces, organise en 4 packages distincts :

- **api** -- Serveur API base sur le framework Hono, exposant les endpoints REST
- **web** -- Application front-end (interface utilisateur)
- **shared** -- Bibliotheques partagees entre les packages
- **sandbox** -- Environnement d'execution isole pour les agents

Couche de Donnees

- **ORM** : Drizzle ORM connecte a PostgreSQL
- **Schema** : 12 tables relationnelles couvrant utilisateurs, tenants, projets, executions, etc.
- **Cache** : Redis avec architecture L1/L2 (cache local + distribue)

Observabilite et Securite

- **OpenTelemetry SDK** : Instrumentation integree pour traces et metriques
- **RBAC** : Systeme de controle d'accès base sur 5 roles distincts
- **MoA Kernel** : Noyau Mixture of Agents avec cascade a 3 tours
- **RL Router** : Routeur LLM adaptatif par apprentissage par renforcement

Metriques Globales du Code

Metrique	Valeur
Fichiers source	251
Lignes de code (approx.)	26 500
Packages monorepo	4
Tables PostgreSQL	12
Roles RBAC	5
Cascading rounds MoA	3

Section 2 : Couverture OpenTelemetry

L'integration OpenTelemetry constitue un pilier de l'observabilite du projet. L'audit a evalue la profondeur et l'etendue de l'instrumentation OTEL.

Composants OTEL Implementes

- **SDK Initialization** : Exporters OTLP HTTP configures pour traces et metriques
- **TracingService** : Gestion du cycle de vie des spans (creation, attribution, fermeture)
- **MetricsService** : Compteurs, histogrammes, up/down counters operationnels
- **AlertManager** : Evaluation de regles d'alerte basees sur les metriques collectees
- **ObservabilityMiddleware** : Creation automatique de spans pour chaque requete HTTP

Nouvelles Traces Ajoutees (Sprint ECS)

Durant le sprint de certification, des traces supplementaires ont ete ajoutees pour couvrir les chemins critiques precedemment non instrumentes :

Domaine	Operations Tracees
AUTH	login, register, mfa_verify, token_refresh, logout
TENANT	create, resolve, quota_check, billing
AI	execute, reflection, autofix, llm.call, llm.routing
CACHE	hit, miss, set

Couverture Actuelle

- Environ **70%** des chemins critiques sont desormais traces
- ✓ **Amelioration significative par rapport a l'etat initial (25%)**

Lacunes Restantes

- **LACUNE** : Traces de requetes base de donnees (DB query spans) non encore ajoutees
- **LACUNE** : Traces au niveau des rounds MoA (Mixture of Agents) manquantes

Section 3 : Resultats TLS

Score TLS : 82 / 100

Amelioration par rapport au score initial de 68/100 (+14 points)

Verifications Reussies

Controle	Statut
TLS 1.2+ obligatoire	VERIFIE
TLS 1.3 actif	VERIFIE
Redirection HTTP vers HTTPS (301)	VERIFIE
HSTS (2 ans, includeSubDomains, preload)	VERIFIE
Suites de chiffrement fortes uniquement	VERIFIE
En-tetes de securite (CSP, X-Frame-Options, COOP/CORP/COEP)	VERIFIE
Cookies securises (Secure, SameSite=Strict, HttpOnly)	VERIFIE
Middleware de redirection HTTPS	VERIFIE

Ameliorations Apportees Durant le Sprint

- ✓ OCSP Stapling : desormais active (precedemment commente)
- ✓ Parametres DH : generation 4096-bit ajoutee
- ✓ En-tetes de securite des assets statiques : les 10 en-tetes sont presents

Lacunes Restantes

- LACUNE : Pas d'integration Let's Encrypt (P0 - priorite maximale)
- LACUNE : Pas de renouvellement automatique des certificats (P0)

Section 4 : Resultats PenTest

Score PenTest : 72 / 100

Resultats par Categorie de Test

Test	Resultat	Details
XSS (Cross-Site Scripting)	PASS	CSP strict, pas d'innerHTML, entrees sanitisees
Injection SQL	PASS	Drizzle ORM avec requetes parametrees
Abus JWT	PASS	Validation complete des claims, verification de type, liste noire
CSRF	RISQUE FAIBLE	Authentification par Bearer token, pas de cookies
Fixation de Session	PASS	Nouvelle session a la connexion, token MFA separe
Contournement RBAC	PARTIEL	Certaines routes agent sans requirePermission
IDOR / Echappement Tenant	PARTIEL	Projets filtres par userId pas tenantId, cancel sans verification
Contournement Rate Limiting	PARTIEL	X-Forwarded-For confiance, Redis fail-open
Escalade de Privileges	RISQUE FAIBLE	Claim JWT de tier potentiellement obsolete

Bilan des Vulnerabilites Detectees

Severite	Nombre
Critique (P0)	0
Elevee (P1)	4
Moyenne (P2)	4
Faible (P3)	2
Total	10

Section 5 : Resultats Supply Chain

Score Supply Chain : 55 / 100

Amelioration par rapport au score initial de 33/100 (+22 points)

Vulnerabilites CVE Identifiees

Dependance	Severite	Description
vitest	Critique	CVE non specifiee
drizzle-orm	Elevee	Injection SQL potentielle
OpenTelemetry SDK	Elevee	Deni de service (DoS)

Ameliorations Apportees Durant le Sprint

- ✓ Secrets codes en dur (fallback) : supprimes avec garde de production
- ✓ Dockerfiles web : execution en utilisateur non-root (USER nginx)
- ✓ JWT_SECRET par default : longueur minimale passe a 32 caracteres (etait 16)
- ✓ MFA_ENCRYPTION_KEY par default : longueur minimale passe a 32 caracteres (etait 16)
- ✓ Garde de production : rejection des secrets par default en environnement de production

Points Positifs Existants

- API Dockerfile : utilisateur non-root, healthcheck, base alpine

Lacunes Restantes

- LACUNE : 6 connexions Redis separees (consolidation necessaire)
- LACUNE : 1 CVE critique (vitest) non resolue
- LACUNE : 2 CVE elevees non resolues (drizzle-orm, OTel)

Section 6 : Resultats Charge

Score Charge : 52 / 100

Analyse des Goulots d'Etranglement

Composant	Observation	Evaluation
Pool PostgreSQL	max 20, code en dur	Non configurable via env
Connexions Redis	6 connexions separees	Pas de pooling de connexions
Couverture Rate Limiting	~8% des endpoints	Couverture tres insuffisante
SSE Backpressure	Pas de verification desiredSize	Risque de fuite memoire
Cout bcrypt	Facteur 12 (~200ms/login)	Acceptable mais non configurable
Deduplication requetes	VERIFIEE et fonctionnelle	Bon
Cache L1/L2 borne	1000 / 2000 entrees	Bornes configurees
Fuite memoire EventManager	eventHistory pour executions pendantes	Risque identifie

Points Positifs

- ✓ Deduplication des requetes : verifiee et operationnelle
- ✓ Cache L1/L2 : bornes de taille correctement configurees (1000/2000)

Lacunes Critiques

- **LACUNE : Pool PostgreSQL non configurable dynamiquement via variables d'environnement**
- **LACUNE : 6 connexions Redis separees sans pooling -- gaspillage de ressources**
- **LACUNE : Couverture du rate limiting a seulement 8% des endpoints**
- **LACUNE : Pas de verification desiredSize pour SSE (risque de backpressure non gere)**

Section 7 : Resultats Resilience

Score Resilience : 49 / 100

Tests de Resilience par Scenario

Scenario	Score	Observation
Crash PostgreSQL	4/10	Driver se reconnecte mais pas de gestion applicative
Crash Redis	9/10	Tous les services se degradent progressivement
Redis rate limiting auth	5/10	Echec en mode OPEN (rate limiting desactive)
Panne fournisseur LLM	3/10	PAS de basculement vers un fournisseur alternatif
Echec partiel LLM	8/10	Promise.allSettled gere correctement les echecs partiels
Arret progressif (graceful shutdown)	4/10	Handler present mais pas de drainage des requetes
Pipeline Auto-Fix (3 niveaux)	8/10	Escalade a 3 niveaux VERIFIEE
Journal de recuperation erreurs	1/10	Table fantome, jamais ecrite
Health checks (/readyz)	7/10	Verifie DB+Redis mais cree nouvelle connexion Redis par appel

Points Positifs

- ✓ Redis crash : degradation gracieuse excellente (9/10)
- ✓ Echec partiel LLM : gestion robuste via Promise.allSettled (8/10)
- ✓ Pipeline Auto-Fix : escalation a 3 niveaux verifiee (8/10)

Lacunes Critiques

- LACUNE : Aucun basculement LLM provider en cas de panne (3/10) -- risque majeur
- LACUNE : Table de journalisation des erreurs fantome (1/10) -- aucune donnee ecrite
- LACUNE : Pas de drainage des requetes en cours lors de l'arret progressif (4/10)
- LACUNE : Health check /readyz cree une nouvelle connexion Redis a chaque appel

Section 8 : Resultats Multi-Tenant

Score Multi-Tenant : 62 / 100

Amelioration par rapport au score initial de 48/100 (+14 points)

Isolation Verifiee

- ✓ **Billing/Invoices** : bien isole (filtre par tenantId)
- ✓ **Routes d'administration tenant** : bien protegees (requirePermission)
- ✓ **CacheManager** : desormais espace de noms par tenantId (partage entre tenants corrig)
- ✓ **Projets** : filtres par tenantId lorsque le contexte tenant est present

Lacunes d'Isolation

Composant	Lacune	Severite
cost_tracking	Pas de colonne tenantId	Elevee
rl_training_data	Pas de colonne tenantId	Moyenne
analytics_events	Pas de colonne tenantId	Elevee
X-Tenant-Id header	Non valide contre l'appartenance utilisateur	Elevee
Routes execution agent	Ne respectent pas les quotas tenant	Moyenne
Annulation d'execution	Pas de verification de propriete	Moyenne

Section 9 : Resultats IA

Score IA : 83 / 100

Composants IA Evalues

Composant	Statut	Details
MoA (CodeGenerator)	VERIFIE	Cascade 3 tours, fournisseurs paralleles, vote pondere
Agent de Reflexion	VERIFIE	Evaluation LLM reelle, 6 criteres, seuil 0.95
Routeur RL	PARTIEL	Epsilon-greedy OK, mais pas de failover provider, hydrateFromDatabase jamais appele
Pipeline Auto-Fix	PARTIEL	L1 Pattern OK, L2 utilise regex (pas AST reel), L3 LLM OK
Optimiseur de Cout	VERIFIE	Inspire RL, niveaux de budget, suivi historique
Gestion du Contexte	VERIFIE	ContextGraph, TokenBudgetManager, CompressionService integres
AstTransformService	FANTOME	Existe mais n'est jamais appele

Points Forts

- ✓ MoA : implementation solide avec cascade a 3 tours et vote pondere
- ✓ Agent de Reflexion : evaluation LLM authentique avec 6 criteres rigoureux
- ✓ Optimiseur de Cout : suivi budgetaire intelligent inspire de l'apprentissage par renforcement
- ✓ Gestion du Contexte : architecture complete avec ContextGraph, TokenBudgetManager et CompressionService

Lacunes

- LACUNE : Routeur RL : hydrateFromDatabase n'est jamais appele au demarrage -- le routeur ne charge pas l'historique
- LACUNE : Pipeline Auto-Fix L2 : utilise des expressions regulieres au lieu d'un veritable AST
- LACUNE : AstTransformService : service fantome qui n'est jamais invoque dans le code

Section 10 : Vulnerabilites Restantes

Le tableau ci-dessous recapitule l'ensemble des vulnerabilites identifiees lors de l'audit qui restent non resolues a la fin du sprint de certification.

ID	Vulnerabilite	Severite	Statut
V-01	SSE CORS wildcard	Moyen	Ouvert
V-02	Cancel execution sans verification propriete	Moyen	Ouvert
V-03	X-Forwarded-For trusted sans validation	Moyen	Ouvert
V-04	Redis fail-open desactive rate limiting	Moyen	Ouvert
V-05	Routes agent admin sans RBAC	Moyen	Ouvert
V-06	Tables sans tenantId (cost_tracking, etc.)	Moyen	Ouvert
V-07	X-Tenant-Id non valide contre membership	Eleve	Ouvert
V-08	Pas de failover LLM provider	Eleve	Ouvert
V-09	Pas de Let's Encrypt	Eleve	Ouvert
V-10	AstTransformService ghost	Bas	Ouvert
V-11	RLTrainingService hydratation non appelee	Bas	Ouvert
V-12	Rate limiting couverture 8%	Eleve	Ouvert

Repartition par severite : 4 vulnerabilites Elevees, 6 Moyennes, 2 Faibles -- total de 12 vulnerabilites ouvertes. Les vulnerabilites elevees (V-07, V-08, V-09, V-12) doivent etre resolues en priorite pour atteindre la certification Enterprise.

Section 11 : Score Certifie par Domaine

Le tableau suivant presente l'evolution des scores par domaine entre l'etat initial (avant le sprint ECS) et l'etat final (apres le sprint ECS).

Domaine	Score Avant	Score Apres	Delta
TLS/HTTPS	68	82	+14
Sessions Distribuees	30	75	+45
Observabilite	25	70	+45
PenTest	72	72	0
Supply Chain	33	55	+22
Charge	52	52	0
Resilience	49	49	0
Multi-Tenant	48	62	+14
Agents IA	83	83	0
CI/CD	60	65	+5

Analyse des Progressions

Les ameliorations les plus significatives ont ete realisees dans les domaines Sessions Distribuees (+45) et Observabilite (+45), passant respectivement de 30 a 75 et de 25 a 70. Ces progres notables decoulent de l'integration Redis pour les sessions et de l'ajout massif de traces OpenTelemetry couvrant les chemins critiques.

Les domaines PenTest (72), Charge (52), Resilience (49) et Agents IA (83) n'ont pas progresse durant ce sprint, faute de temps ou de priorite. La Resilience reste le domaine le plus faible avec un score de 49/100, principalement en raison de l'absence de basculement LLM provider et de la table de journalisation fantome.

Section 12 : Score Global Certifie

Calcul Pondere

Le score global est calcule comme une moyenne ponderee des quatre axes strategiques :

Axe	Calcul	Score
Securite (TLS + PenTest + Supply Chain)	$(82 + 72 + 55) / 3$	69.7
Infrastructure (Sessions + Observabilite + Charge + Resilience)	$(75 + 70 + 52 + 49) / 4$	61.5
Donnees (Multi-Tenant + RBAC)	62	62.0
Intelligence Artificielle (Agents)	83	83.0

SCORE GLOBAL CERTIFIE

62 / 100

CLASSIFICATION : PRE-ENTERPRISE

(Plage 60-69)

Conditions Minimales pour la Certification Enterprise

Pour atteindre la certification Enterprise (score 70-79), les conditions suivantes doivent etre satisfaites :

- Resolution de toutes les vulnerabilites P0 (actuellement 0, mais V-07 a V-09 sont P0 potentielles)
- Couverture du rate limiting a 80% minimum (actuellement 8%)
- Implementation du basculement LLM provider (failover automatique)
- Integration de Let's Encrypt avec renouvellement automatique
- Isolation multi-tenant absolue (tenantId sur toutes les tables, validation X-Tenant-Id)

Echelle de Classification

Classification	Plage de Score
Beta	< 50
Production	50 - 59

Classification	Plage de Score
Production+	60 - 69
Pre-Enterprise	70 - 79
Enterprise	80 - 89
Enterprise+	90 - 94
Enterprise Elite	95+

Fin du rapport -- AgentForge Enterprise Certification Sprint -- 04 Juin 2026

Document confidentiel -- Diffusion restreinte aux parties autorisees